

Operations Governance Master Handbook

Production Governance and Operational Excellence framework for the SANAD enterprise platform. Defines monitoring, incident management, change control, release governance, security operations, backup strategy, cost management, and runbook procedures.

VERSION

STATUS

CLASSIFICATION

DATE

v1.0

Draft For Approval

Internal

June 2026

Operations Governance Model

The SANAD Operations Governance Model establishes a structured hierarchy of decision-making authority, accountability, and operational control across the platform lifecycle. This model ensures that every operational action — from routine monitoring to emergency incident response — is governed by clearly defined roles, escalation paths, and approval gates. The governance framework is designed to support a multi-tenant enterprise platform where reliability, security, and compliance are non-negotiable requirements.

Strategic Layer

The Strategic Layer is responsible for the long-term direction and sustainability of the SANAD platform. This layer sets the vision, approves budgets, and accepts residual risks that cannot be mitigated at the operational level. Strategic decisions are made by senior stakeholders who have the authority to commit organizational resources and accept risk on behalf of the business.

ROLE	RESPONSIBILITY
Product Owner	Defines platform roadmap, approves feature prioritization, and ensures business alignment of all platform changes
Executive Sponsor	Provides organizational authority, approves budget allocation, and serves as the final escalation authority for cross-cutting disputes
Program Governance Board	Reviews quarterly platform health, approves SLA targets, accepts risk transfer decisions, and authorizes major architectural changes

Operational Layer

The Operational Layer is responsible for the day-to-day execution of platform operations. This layer handles monitoring, incident response, change execution, and release operations. Operational teams are the first responders when systems deviate from expected behavior, and they are empowered to take corrective action

within defined parameters without requiring strategic-level approval for every decision.

ROLE	RESPONSIBILITY
Platform Operations	Continuous monitoring of application and infrastructure health, first-response triage, and routine maintenance execution
DevOps	CI/CD pipeline management, deployment execution, configuration management, and infrastructure-as-code maintenance
Security Operations	Threat detection, vulnerability assessment, access review, secret rotation, and audit log management

The separation between Strategic and Operational layers ensures that tactical decisions are made quickly by those closest to the problem, while strategic alignment is maintained through periodic reviews, approval gates, and escalation procedures. Each layer operates within a clearly defined decision boundary — operational teams can execute standard procedures autonomously, while any decision that affects SLAs, security posture, or budget must be escalated to the Strategic Layer.

SECTION 2

Monitoring & Observability

A robust monitoring and observability framework is the foundation of production operations. Without real-time visibility into application behavior, database performance, and infrastructure health, the operations team is effectively flying blind. SANAD's monitoring strategy is designed to provide comprehensive coverage across three domains — Application, Database, and Infrastructure — with alerting thresholds calibrated to detect anomalies before they become customer-facing incidents.

Monitoring Domains

Application Monitoring

- **API Latency** — Track p50, p95, and p99 response times across all REST endpoints. Baseline under 200ms p95; alert at 500ms p95.
- **Request Volume** — Monitor requests per minute to detect traffic spikes, DDoS patterns, or unexpected drops in usage that may indicate upstream failures.
- **Error Rate** — Track HTTP 4xx and 5xx error rates. Alert when 5xx rate exceeds 1% of total requests over a 5-minute window.
- **Authentication Failures** — Monitor failed login attempts and token validation failures. Alert on spikes that may indicate credential stuffing or token compromise.

Database Monitoring

- **Connection Pool** — Track active, idle, and waiting connections. Alert when waiting connections exceed 5, indicating pool exhaustion.
- **Query Duration** — Monitor slow queries exceeding 1 second. Log and alert on queries exceeding 5 seconds for immediate investigation.
- **Deadlocks** — Track deadlock frequency. Any deadlock triggers an alert; more than 3 in a 10-minute window escalates to SEV-2.
- **Storage Growth** — Monitor database size growth rate. Alert when growth exceeds 10% week-over-week to prevent unexpected storage exhaustion.

Infrastructure Monitoring

- **CPU** — Track utilization across all service instances. Alert at 80% sustained for 5 minutes; critical at 90%.
- **Memory** — Monitor heap and RSS usage. Alert at 85% utilization to catch memory leaks before OOM kills.
- **Disk** — Track disk usage and I/O wait. Alert at 75% capacity; critical at 90% to prevent data loss.
- **Network** — Monitor bandwidth, latency, and packet loss between services and external dependencies.

Alert Levels

Alert levels define the maximum acceptable response time and the escalation path for each category of operational anomaly. The four-tier system ensures that

critical issues receive immediate attention while lower-priority items are handled within appropriate timeframes without disrupting ongoing operations.

CRITICAL — RESPONSE WITHIN 15 MINUTES

Production service outage, database unreachable, or authentication system failure. These conditions directly impact all tenants and require immediate mobilization of the on-call engineer. Examples: complete API unavailability, database connection pool exhaustion, or JWT validation service down.

HIGH — RESPONSE WITHIN 1 HOUR

Major business function unavailable or severely degraded. Single-tenant impact or partial service degradation that affects a significant subset of users. Examples: specific API endpoint returning 5xx errors, background job processing stalled, or backup failure.

MEDIUM — RESPONSE WITHIN 4 HOURS

Partial degradation that does not immediately impact core business functions. Performance degradation, non-critical feature unavailability, or monitoring gaps. Examples: elevated API latency (still within SLA), monitoring agent disconnected, or staging environment issues.

LOW — RESPONSE WITHIN 24 HOURS

Minor issues that require attention but do not impact production operations. Documentation gaps, cosmetic defects, or capacity planning observations. Examples: log rotation warning, certificate expiration within 30 days, or minor UI rendering issue.

SECTION 3

Incident Management

Incident management is the structured process by which SANAD operations teams detect, triage, resolve, and learn from service disruptions. The incident management framework defines severity levels, escalation paths, and postmortem requirements to ensure that every incident — from a minor glitch to a full

production outage — is handled consistently, documented thoroughly, and used as an opportunity to improve system resilience.

Severity Matrix

SEVERITY	DEFINITION	RESPONSE TIME	RESOLUTION TARGET	POSTMORTEM REQUIRED
SEV-1	Production outage affecting all tenants. Complete loss of a core platform capability.	15 min	2 hours	Yes — within 48 hours
SEV-2	Major business function unavailable. Significant degradation affecting multiple tenants or a critical workflow.	1 hour	4 hours	Yes — within 5 business days
SEV-3	Partial degradation. A non-critical feature is impaired, or a single tenant experiences reduced functionality.	4 hours	1 business day	Optional — at team discretion
SEV-4	Minor issue. Cosmetic defect, documentation error, or low-impact anomaly with no user-facing effect.	24 hours	Next sprint	No

Escalation Flow

Every incident follows a standardized escalation flow from detection through postmortem. This flow ensures that incidents are not only resolved quickly but that the organization learns from each event to prevent recurrence. The escalation path is designed to be fast for critical issues while providing appropriate oversight for lower-severity events.

Detection



Triage



Assignment



Resolution



Postmortem

Detection

Automated monitoring alerts, user reports, or proactive health checks identify a deviation from expected system behavior. The on-call engineer receives the alert and begins initial assessment within the defined response time for the detected severity level.

Triage

The on-call engineer assesses the scope, impact, and severity of the incident. This includes verifying the alert is genuine (not a false positive), determining which tenants are affected, and classifying the incident according to the severity matrix. If the initial severity assessment is uncertain, the engineer defaults to the higher severity level to ensure rapid response.

Assignment

Based on the triage assessment, the incident is assigned to the appropriate resolver team. SEV-1 and SEV-2 incidents trigger an incident commander who coordinates the response across teams. SEV-3 and SEV-4 incidents are assigned to the relevant team lead for resolution during normal working hours.

Resolution

The assigned team works to restore service. Resolution may involve rolling back a deployment, scaling infrastructure, applying a hotfix, or escalating to a third-party vendor. All actions taken during resolution are logged in the incident timeline for postmortem analysis. Status updates are communicated to stakeholders at regular intervals proportional to severity.

Postmortem

For SEV-1 and SEV-2 incidents, a blameless postmortem is conducted within the specified timeframe. The postmortem document captures the timeline, root cause analysis, impact assessment, and specific action items to prevent recurrence. Action items are tracked as GitHub Issues with assigned owners and due dates.

Change Management

Change management ensures that every modification to the SANAD production environment is planned, reviewed, approved, and executed in a controlled manner. Uncontrolled changes are the leading cause of production incidents — a single undocumented configuration change can cascade into a multi-tenant outage. The SANAD change management process classifies changes by risk level and requires appropriate approval before execution.

Change Types

TYPE	DESCRIPTION	APPROVAL	LEAD TIME
Standard Change	Pre-approved, low-risk changes with a documented history of success. Examples: routine patch updates, scaling operations, log rotation config changes.	Pre-approved (no individual RFC)	None — execute on schedule
Normal Change	Planned changes that carry some risk and require review. Examples: feature deployments, database schema migrations, dependency upgrades.	RFC reviewed and approved per risk level	2 business days minimum
Emergency Change	Urgent changes required to restore service or prevent imminent harm. Examples: hotfix for SEV-1 incident, critical security patch, infrastructure failover.	Verbal approval from Incident Commander or Platform Owner	Immediate — retrospective RFC within 24 hours

Approval Matrix

The approval matrix maps risk levels to the minimum authority required to authorize a change. This ensures that higher-risk changes receive greater scrutiny while low-risk changes can proceed without unnecessary bureaucratic

delays. Every change, regardless of risk level, must be documented in the change log with a unique RFC identifier.

RISK LEVEL	APPROVER	RFC REQUIRED	REVIEW PERIOD
Low Risk	Team Lead	Optional (log entry)	N/A
Medium Risk	Platform Owner	Required	1 business day
High Risk	Governance Board	Required	2 business days

Risk classification is determined by evaluating three factors: blast radius (how many tenants or services are affected), reversibility (how quickly the change can be rolled back), and historical failure rate (has this type of change caused incidents before). Changes that score high on any two of these dimensions are automatically classified as High Risk. All High Risk changes require a documented rollback plan before approval is granted.

SECTION 5

Release Governance

Release governance provides a structured framework for deploying changes to the SANAD production environment. Every release must pass through a defined set of quality gates before it reaches production, ensuring that only validated, secure, and tested code is deployed to the multi-tenant platform. The release process is designed to balance speed of delivery with the reliability requirements of an enterprise system.

Release Types

TYPE	SCOPE	APPROVAL	TYPICAL CADENCE
Hotfix	Critical fix for SEV-1/SEV-2 incident. Minimal scope, single fix.	Incident Commander	As needed
Patch	Non-critical bug fixes, minor security patches. No new features.	Team Lead	Weekly
Minor	New features, enhancements, non-breaking API additions.	Platform Owner	Bi-weekly
Major	Breaking changes, architectural modifications, multi-tenant impact.	Governance Board	Quarterly

Release Gates

Every release must pass through five mandatory quality gates before deployment to production. These gates are enforced by the CI/CD pipeline and cannot be bypassed — even for hotfixes, which must pass all gates on an accelerated timeline. The gates are designed to catch issues early, when they are cheapest and fastest to fix.



Gate 1 — Build Success

The application compiles without errors, all dependencies resolve, and the Docker image builds successfully. This gate catches compilation errors, missing dependencies, and configuration issues before any testing begins.

Gate 2 — Security Scan Pass

Automated dependency scanning (Trivy, Snyk, or equivalent) identifies no critical or high-severity vulnerabilities. Known CVEs with available patches must be resolved before the release proceeds. Medium-severity findings are logged and tracked for resolution within the next patch cycle.

Gate 3 — Regression Pass

The full regression test suite (currently 9 tests covering authentication, RBAC, bootstrap, and API endpoints) executes with 100% pass rate. Any test failure blocks the release and triggers immediate investigation. The regression suite is maintained as a living document and updated with every new feature.

Gate 4 — Smoke Test Pass

Post-deployment smoke tests verify that the application starts correctly, health checks return 200 OK, and core API endpoints respond within acceptable latency thresholds. Smoke tests run against the staging environment before production deployment and against production immediately after deployment.

Gate 5 — Approval Recorded

The appropriate approver (per the release type approval matrix) has reviewed the release notes, acknowledged the risk assessment, and recorded explicit approval in the release management system. No deployment may proceed without a recorded approval entry.

SECTION 6

Security Operations

Security operations encompass the ongoing processes and controls that protect the SANAD platform from threats, vulnerabilities, and unauthorized access. In a multi-tenant enterprise system, security is not a one-time configuration — it requires continuous monitoring, regular reviews, and proactive threat mitigation. The security operations framework defines five core control areas and establishes the review cadence for each.

Security Controls

Secret Rotation

All secrets — JWT_SECRET, database credentials, API keys, and third-party service tokens — are rotated on a defined schedule. JWT_SECRET rotation uses the session version mechanism (implemented in DEFECT-001) to invalidate tokens immediately upon rotation without disrupting active sessions. Database credentials are rotated quarterly using Flyway migration scripts. All rotations are logged and verified.

Access Review

Quarterly access reviews verify that every user's role and permissions align with their current job function. The RBAC authorization matrix (19 capabilities, 6 roles, 72 mappings — validated in DEFECT-007) serves as the baseline. Any discrepancies are remediated within 5 business days. Admin access requires annual re-approval from the Governance Board.

Dependency Scanning

Automated scanning of all application dependencies runs on every pull request and nightly on the main branch. The scanning tool identifies known CVEs, license compliance issues, and end-of-life dependencies. Critical and high-severity findings block releases; medium findings are tracked for remediation within the next sprint.

Vulnerability Assessment

Quarterly vulnerability assessments combine automated scanning with manual penetration testing of critical attack surfaces — authentication flows, RBAC enforcement, multi-tenant data isolation, and API input validation. Findings are classified by severity and tracked to remediation with defined SLAs.

Audit Logging

All authentication events (login, logout, token refresh), authorization decisions (capability checks, role assignments), data access operations (read, write, delete on tenant-scoped resources), and administrative actions (user creation, role changes, configuration modifications) are logged with timestamps, actor identity, and outcome. Audit logs are retained for 12 months and are immutable once written.

Review Frequency

CONTROL	FREQUENCY	OWNER	EVIDENCE
Secret Rotation	Monthly (JWT), Quarterly (DB), Annually (API keys)	DevOps	Rotation log entries
Access Review	Quarterly (all users), Annually (admin re-approval)	Platform Owner	Review report with sign-off
Dependency Scanning	Every PR + Nightly	DevOps	CI pipeline scan results
Vulnerability Assessment	Quarterly	Security Operations	Assessment report with findings
Audit Log Review	Monthly (anomaly detection), Quarterly (full review)	Security Operations	Review report with anomalies

SECTION 7

Backup & Disaster Recovery

Backup and disaster recovery (DR) processes ensure that SANAD can recover from data loss, infrastructure failure, or catastrophic events within defined recovery targets. The backup strategy is designed for the Supabase PostgreSQL database hosted in Frankfurt, with retention policies that balance storage cost against recovery flexibility. Disaster recovery procedures are validated through regular exercises to ensure they work when needed.

Backup Policy

Daily Backup

Automated daily database backups execute at 02:00 UTC via Supabase's built-in pg_dump mechanism. Each backup captures the full database state including schema (Flyway migrations V1-V15), all tenant-scoped data, RBAC mappings, and audit logs. Backups are stored in Supabase-managed cloud storage with server-side encryption. The 30-day retention window provides 30 recovery points, enabling point-in-time recovery for any day within the past month.

PARAMETER	VALUE	RATIONALE
Frequency	Daily (02:00 UTC)	Aligns with lowest traffic window to minimize performance impact
Retention	30 days	Provides one month of recovery points; balances cost against recovery flexibility
Storage	Supabase cloud (encrypted)	Geographic redundancy with EU data residency compliance
Verification	Weekly restore to staging	Confirms backup integrity and validates restore procedures

Recovery Targets

RPO: 24 Hours

The Recovery Point Objective of 24 hours means that in the worst case, up to 24 hours of data may be lost. This is acceptable because the daily backup cadence ensures that at most one day of transactions is at risk. For scenarios requiring lower RPO, point-in-time recovery via Supabase WAL archiving can reduce data loss to minutes.

RTO: 4 Hours

The Recovery Time Objective of 4 hours means that from the declaration of a disaster to full service restoration, the maximum acceptable downtime is 4 hours.

This includes the time to provision replacement infrastructure, restore the database from backup, verify data integrity, and redirect traffic. The 4-hour target has been validated through quarterly DR exercises.

DR Exercise

Disaster recovery exercises are conducted quarterly to validate that the documented recovery procedures work end-to-end. Each exercise simulates a realistic failure scenario — such as complete database loss, region failure, or configuration corruption — and measures the actual recovery time against the 4-hour RTO target. Findings from each exercise are documented and used to improve the recovery procedures. The most recent exercise validated the backup restore workflow (DEFECT-008).

SECTION 8

Cost & Capacity Management

Cost and capacity management ensures that the SANAD platform operates within budget while maintaining sufficient headroom for growth. Without proactive capacity planning, the platform risks either over-provisioning (wasting budget) or under-provisioning (risking performance degradation and outages). The cost management framework tracks spending across all service providers and projects future requirements based on usage trends.

Services

SERVICE	PROVIDER	CURRENT TIER	MONTHLY ESTIMATE
Backend Hosting	Render	Starter (auto-scale)	Variable based on usage
Frontend Hosting	Vercel	Hobby / Pro	Based on bandwidth and build minutes
Source Control / CI	GitHub	Team plan	Fixed monthly
Database	Supabase	Pro (Frankfurt region)	Based on database size and bandwidth

Metrics

Monthly Cost Tracking

Actual spending is tracked against budget on a monthly basis. Variance exceeding 15% triggers a review by the Platform Owner. Cost anomalies — such as unexpected spikes in Render compute charges or Supabase bandwidth — are investigated and documented. Monthly cost reports are shared with the Executive Sponsor.

Usage Trend Analysis

Key usage metrics — API request volume, active users, database size, and storage consumption — are tracked weekly and plotted monthly. Trends are analyzed to identify growth patterns, seasonal variations, and anomalous spikes. Usage trends inform capacity planning decisions and budget forecasting.

Capacity Forecast

Based on usage trends, a 90-day capacity forecast is generated monthly. The forecast predicts when current service tiers will reach capacity limits (e.g., 80% of Render memory, 75% of Supabase storage). When a forecast indicates that a capacity threshold will be breached within the forecast window, a capacity upgrade request is submitted through the change management process.

Growth Forecast

Quarterly growth forecasts project platform scale over the next 6-12 months based on business development pipeline, planned feature launches, and historical growth rates. Growth forecasts feed into annual budget planning and infrastructure architecture reviews. Forecasts that project more than 50% growth in any dimension trigger a strategic architecture review.

SECTION 9

Runbooks

Runbooks are step-by-step operational procedures that guide the on-call engineer through common failure scenarios. Every runbook follows a standard format: symptoms, initial assessment, step-by-step resolution, verification, and post-incident actions. Runbooks are living documents that are updated after every incident to incorporate lessons learned. The following six runbooks are mandatory and must be reviewed quarterly for accuracy.

1. Production Outage Runbook

Triggers: Health check failures, complete API unavailability, or user reports of total service loss. Initial assessment: Verify monitoring alerts are genuine, check Render and Supabase status pages, and determine scope (all tenants vs. single tenant). Resolution: Escalate to SEV-1, activate incident commander, and follow the incident management escalation flow. Common resolution paths include restarting the Render service, failing over to a backup database, or rolling back the most recent deployment.

2. Database Failure Runbook

Triggers: Connection pool exhaustion, query timeouts exceeding 30 seconds, or Supabase status page reporting degraded performance. Initial assessment: Check Supabase dashboard for active incidents, verify connection pool metrics, and test direct database connectivity. Resolution: Reduce connection pool size, terminate long-running queries, or restore from the most recent daily backup. If the failure is due to storage exhaustion, perform emergency cleanup of audit logs or temporary data.

3. Authentication Failure Runbook

Triggers: Spike in authentication failure alerts, users unable to log in, or token validation errors across API endpoints. Initial assessment: Check `JWT_SECRET` configuration, verify token expiry settings, and examine authentication service logs for patterns. Resolution: If `JWT_SECRET` was inadvertently rotated, restore the previous value and re-issue tokens. If the issue is due to a code deployment, roll back to the last known-good version. If caused by a credential stuffing attack, enable rate limiting and notify affected tenants.

4. Deployment Rollback Runbook

Triggers: Post-deployment smoke test failures, sudden increase in error rates, or user reports of new bugs. Initial assessment: Identify the most recent deployment, compare error rates before and after, and confirm the deployment is the root cause. Resolution: Execute Vercel rollback for frontend changes, re-deploy the previous Docker image for backend changes, and revert any database schema migrations using Flyway undo scripts. Verify that all health checks pass after rollback.

5. Backup Restore Runbook

Triggers: Data corruption, accidental deletion, or disaster recovery exercise. Initial assessment: Determine the point-in-time to restore to, verify the backup exists and is not corrupted, and estimate restore duration. Resolution: Connect to Supabase dashboard, initiate restore from the target backup, verify data integrity after restore, and re-validate all health checks. Document the restore operation including start time, end time, and any issues encountered.

6. Secret Rotation Runbook

Triggers: Scheduled rotation, suspected compromise, or post-incident remediation. Initial assessment: Identify all secrets that need rotation, verify the new values are generated and available, and confirm the session version mechanism is active. Resolution: For `JWT_SECRET` rotation, update the environment variable on Render, increment the session version, and verify that old tokens are rejected while new tokens are accepted. For database credentials, create new credentials, update the application configuration, and invalidate old credentials. Document all rotation operations in the audit log.

Exit Criteria

PGOE-001 is considered complete only when all eight governance workflows are demonstrably active and operational in the production environment. "Active" means that the process is not merely documented but is being followed in practice, with evidence of execution in the form of completed runs, logged events, or audit records. The following exit criteria must all be satisfied before the program can be declared complete. Each criterion includes both a qualitative description and specific quantitative evidence requirements that must be presented to the Governance Board for review.

- ☐ **Monitoring Active** — Application, database, and infrastructure monitoring is operational with alerting configured for all defined metrics. At least one complete monitoring cycle (7 days) has been observed without gaps. Evidence: Dashboard screenshots showing continuous metric collection, alert configuration export, and 7-day uptime report.
- ☐ **Alerting Active** — Alert levels (Critical, High, Medium, Low) are configured and tested. At least one alert has been triggered and handled according to the defined response procedures. Evidence: Alert configuration export, incident ticket demonstrating alert-triggered response, and response time compliance report.
- ☐ **Incident Process Active** — The severity matrix and escalation flow are documented, communicated to all operations team members, and at least one incident (real or simulated) has been handled through the full process including postmortem. Evidence: Incident ticket with complete timeline, postmortem document with action items, and team acknowledgment records.
- ☐ **Change Process Active** — The change type classification and approval matrix are implemented. At least one Normal Change has been processed through the full RFC lifecycle, and at least one Emergency Change has been executed with retrospective documentation. Evidence: RFC records, approval logs, and retrospective change documentation.
- ☐ **Release Governance Active** — All five release gates are enforced in the CI/CD pipeline. At least one release of each type (Hotfix, Patch, Minor) has successfully passed through all gates. Evidence: CI/CD pipeline configuration, gate check logs, and release records for each type.

- ☐ **Security Operations Active** — All five security controls are operational. At least one secret rotation, one access review, and one dependency scan have been completed and documented. Evidence: Rotation audit logs, access review report with sign-off, and dependency scan results with remediation status.
- ☐ **Backup Governance Active** — Daily backups are executing on schedule, at least one restore verification has been completed successfully, and a DR exercise has been conducted with documented results. Evidence: Backup execution logs, restore verification report, and DR exercise findings document.
- ☐ **Capacity Governance Active** — Monthly cost tracking is operational, usage trends are being collected, and at least one capacity forecast has been generated and reviewed. Evidence: Cost tracking dashboard, usage trend charts, and capacity forecast document with review sign-off.

Upon verification that all eight exit criteria are satisfied, the Program Governance Board convenes to review the evidence and make a formal determination. The board reviews each criterion individually, requesting additional evidence or clarification as needed. If any criterion is found to be insufficiently demonstrated, the program remains open until the deficiency is addressed. Only when all eight criteria pass board review does the program closure take effect.

If the board approves, the following declarations take effect immediately and are recorded in the program documentation. These declarations represent the formal transition of SANAD from a development-stage platform to an enterprise production-ready system, subject to ongoing governance as defined in this handbook.

DECLARATION	VALUE
Program Status	PGOE-001 = CLOSED
Platform Status	SANAD = ENTERPRISE PRODUCTION READY

Enterprise Production Ready

SANAD has met all operational governance requirements. The platform is certified for enterprise production operations.

SANAD-PGOE-001